

Secure SDLC Lifecycle Case Study

Foodereum: Blockchain-Based Food Supply Chain Traceability System

1. Executive Summary

Foodereum started as a final-year B.E. team project where we built a working blockchain-based traceability platform, and later evolved into my individual application-security capstone during my MS in Cybersecurity Engineering at the University of Washington.

The undergraduate phase (End 2021 – June 2022) involved the collaborative design and implementation of a decentralized web application by a **team of three students under faculty supervision**. The completed system was externally evaluated at the institutional project showcase and was awarded the **Best Project Award (June 2022)** for its innovation, technical completeness, and real-world applicability.

The same system was independently reassessed during the final year of my master's program (Mid 2023 – Mid 2024) after obtaining formal consent from my teammates. This phase focused on identifying application-layer vulnerabilities and implementing secure development controls aligned with Secure Software Development Lifecycle (Secure SDLC) principles.

The original undergraduate implementation is available for technical reference: <https://github.com/gautamK007/Foodereum>

2. Academic & Project Timeline

Bachelor of Engineering (B.E.) – Computer Science & Engineering

Dayananda Sagar College of Engineering, Bengaluru

Final-Year Project Execution: **End 2021 – June 2022**

Team of three students under faculty supervision

Outcome: **Best Project Award – DSCE Project Open-Day**

Master of Science – Cybersecurity Engineering

University of Washington, Bothell

Capstone Execution: **Mid 2023 – Mid 2024**

Individual security assessment with formal team consent

3. Project Overview

3.1 Problem Statement

Traditional food supply chains rely on centralized data storage and manual verification processes, which limit transparency and make it difficult to verify product authenticity, trace contamination sources, and prevent unauthorized data modification.

3.2 Engineering Objectives (Undergraduate Phase)

- Design and implement a working blockchain-integrated web application
- Record product lifecycle events using smart contracts
- Enable stakeholders to verify product history through immutable transactions

3.3 Security Objectives (Master's Capstone Phase)

- Perform a structured application security assessment
- Identify vulnerabilities affecting confidentiality, integrity, and access control
- Implement secure development controls to reduce system risk.

The goal was not only to build a working system, but to evaluate how trust is established and enforced across its lifecycle.

4. System Scope

In Scope

- Web application interface
- Smart contract interaction layer
- Authentication and access control workflow
- Product transaction processing

Out of Scope

- Blockchain consensus mechanism
- External hosting infrastructure

5. Technology Stack

Development

Solidity, Ethereum (Ganache), Web3 integration, frontend and backend web technologies

Security Assessment

Manual testing approach aligned with OWASP methodology

This architecture introduces separate trust boundaries between the UI, transaction layer, and smart contracts, each requiring independent security validation.

6. Undergraduate Engineering Phase – Team Development

Foodereum was originally built as a final-year B.E. project by a team of three under faculty guidance, where we delivered a fully working decentralized application.

My individual contributions included participation in smart contract development and testing, assisting in blockchain integration with the web application, supporting backend transaction workflows, contributing to deployment and functional validation, and participating in gas-based performance evaluation.

The completed system was demonstrated before a technical review panel and received the **Best Project Award**, representing external validation of implementation quality, innovation, and real-world relevance.

6.1 Significance of the Award

The award was based on:

- live system demonstration
- architectural completeness
- practical applicability

This reflects successful delivery of a production-style decentralized application within an academic lifecycle.

7. System Architecture & Operational Workflow

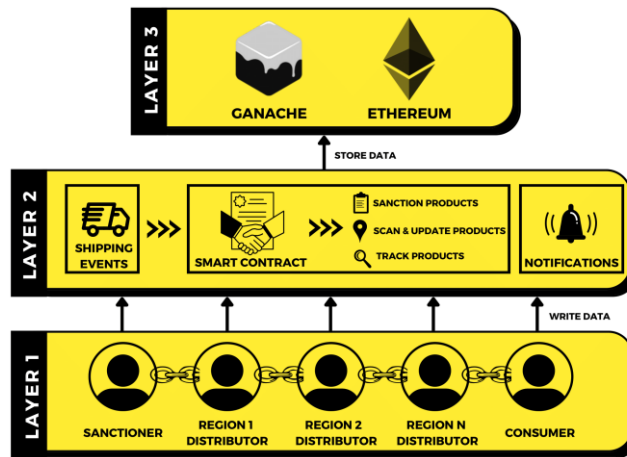


Figure 1: Three-layer architecture with stakeholders, smart contract logic, and blockchain storage

This architecture separates stakeholder interaction, application workflow enforcement, and blockchain persistence. The web application acts as the policy enforcement point where product lifecycle rules are validated before transactions are submitted on-chain. This separation enables independent verification of traceability while also introducing distinct trust boundaries between the user interface, transaction generation logic, and smart contract execution.

8. Performance & Cost Analysis

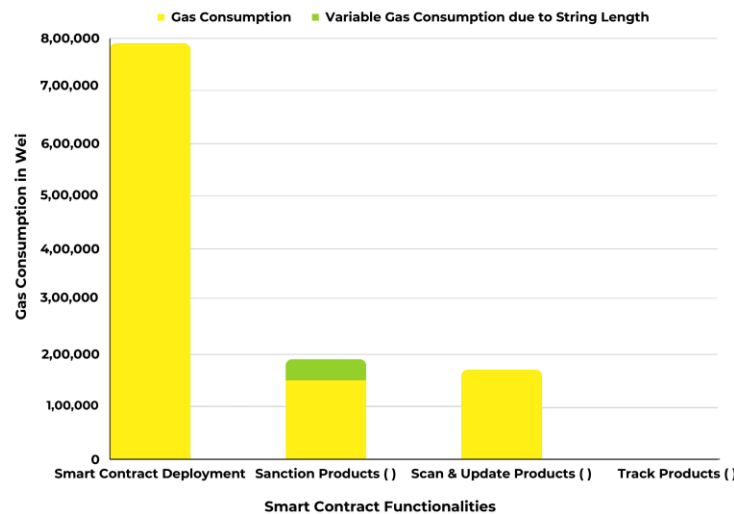


Figure 2: Gas cost comparison for deployment, product registration, ownership transfer, and traceability queries

The gas profile highlights the one-time deployment cost compared to the lower operational cost of product registration, ownership transfer, and traceability queries. This demonstrates that the system is economically viable for repeated supply chain operations and reflects the practical trade-off between immutability and transaction cost in blockchain-based implementations.

9. Research & Publication Outcome

Foodereum: A Blockchain-based Authenticated Solution for Food Supply Chain

Conference: 2022 IEEE North Karnataka Subsection Flagship International Conference (NKCon)

DOI: <https://doi.org/10.1109/NKCon56289.2022.10126555>

This paper presents the system architecture, smart contract workflow, stakeholder interaction model, and gas-based performance evaluation of the Foodereum platform.

A Literature Review on Consortium Blockchain Consistency to Improve Traceability in Food Supply Chain System

Journal: International Journal of Engineering and Advanced Technology (IJEAT)

DOI: <https://doi.org/10.35940/ijeat.c3375.0211322>

This publication analyzes blockchain consistency mechanisms and their role in improving traceability in decentralized supply chain environments.

10. Transition to MS Capstone – From System Developer to Security Assessor

During the final year of the master's program, the same system was re-engaged from an application security perspective with formal consent from the original team. This phase marked the transition from system development to adversarial evaluation and Secure SDLC implementation.

11. Security Assessment Methodology

The assessment focused on whether application-layer controls could be bypassed while still generating valid blockchain transactions. The testing mapped how user roles interacted with lifecycle functions, how transaction parameters were constructed, and where workflow validation occurred before on-chain submission. This made it possible to determine whether an unauthorized actor could perform legitimate-looking product state changes without violating smart contract rules, thereby exposing gaps between blockchain immutability and real access control enforcement.

12.Key Security Risks Identified & Impact

The review identified conditions where authorization checks performed at the client layer could allow unauthorized lifecycle actions, directly affecting the integrity of traceability records. Exposure of internal workflow identifiers increased the risk of targeted transaction manipulation, while insufficient validation of user-controlled parameters created the possibility of logically inconsistent product movement. These issues demonstrate that blockchain immutability alone cannot guarantee system trust without strong application-layer enforcement.

13.Secure Re-Engineering & Risk Reduction

Authorization logic was moved from client-controlled workflows to server-side enforcement, ensuring that only verified stakeholder roles could construct and submit lifecycle transactions. All state transitions were validated against a predefined product workflow, preventing unauthorized creation, transfer, or modification of traceability records. Internal asset identifiers and transaction context were removed from client responses to eliminate enumeration and targeted manipulation risks.

As a result, product history recorded on-chain now reflects only verified and policy-compliant actions, meaning the integrity of the supply chain is enforced by the application's access control and workflow validation rather than being implicitly trusted to the blockchain layer.

14.Recognition – Best Project Award



Figure 3: Best Project Award – DSCE Project Open-Day (June 2022)

This award reflects external technical evaluation of the working system and validates the successful delivery of a production-style decentralized application within the undergraduate engineering lifecycle.

15. Conclusion

Foodereum represents the complete lifecycle of my evolution from system developer to application security practitioner. What began as a collaborative undergraduate engineering project resulted in a working decentralized application that was externally recognized for its technical implementation and real-world relevance. The same system later became the foundation for my individual cybersecurity capstone, where I reassessed it from an adversarial perspective and implemented Secure SDLC-aligned controls.

This progression demonstrates my ability to understand how complex systems are built, how trust is established in distributed architectures, and how that trust can fail when application-layer security is not enforced correctly. By returning to a system I helped develop and evaluating it through a security lens, I was able to connect software engineering, research, and application security into a single, practice-driven workflow.

The outcome of this work is not only a functional blockchain-based traceability platform, but a repeatable approach to analyzing and securing real-world applications — an approach that now informs my professional work in vulnerability assessment and penetration testing and will continue to guide my growth in offensive and product security.

16. References

Research Publications:

- [1] [V. Kumaresh, G. Kumar, R. K. Bhat, and N. J., “Foodereum: A Blockchain-based Authenticated Solution for Food Supply Chain,” 2022 IEEE North Karnataka Subsection Flagship International Conference \(NKCon\). IEEE, pp. 1–5, Nov. 20, 2022. doi: 10.1109/nkcon56289.2022.10126555](#)
- [2] [Kumar, G., Kumaresh, V., Bhat, R. K., & J, Dr. N. \(2022\). A Literature Review on Consortium Blockchain Consistency to Improve Traceability in Food Supply Chain System. International Journal of Engineering and Advanced Technology, 11\(3\), 62–67. <https://doi.org/10.35940/ijeat.c3375.0211322>](#)

Project Reports:

- [3] [Foodereum: A Blockchain-based Authenticated Solution for Food Supply Chain](#)
Undergraduate Final Year Project Report
- [4] [Foodereum: Revolutionizing Food Supply Chains with Blockchain Authentication](#)
MS Cybersecurity Capstone Project Report

Source Repository:

Foodereum – Blockchain-based Food Supply Chain Traceability System
<https://github.com/gautamK007/Foodereum>